

אבטחת אפליקציות Web

מודול 9 — OWASP Top 10

◀ כיצד עובדות חולשות Web

◀ OWASP Top 10

◀ SQLi · XSS · Command Injection

◀ Access Control · File Upload · הגנה

איך עובדת אפליקציית Web?

◀ דפדפן → בקשת HTTP → שרת → DB → תשובה

◀ **השורש:** אמון בקלט משתמש

◀ קלט לא מסונן = הזרקת קוד/פקודות

◀ הכלי המרכזי: **Burp Suite**

OWASP Top 10

A01 Broken Access Control (הנפוץ) ◀

A03 Injection — SQLi, Command, XSS ◀

A05 Misconfiguration · A07 Auth ◀

A06 Vulnerable Components · **A10 SSRF** ◀

סביבת התרגול

◀ PHP — DVWA פגיע, רמות קושי

◀ 100 — OWASP Juice Shop + אתגרים

◀ `docker run -d -p 3000:3000 bkimminich/juice-shop`

◀ PortSwigger Web Security Academy (חינמי)

SQL Injection

◀ קלט נכנס לשאילתת SQL

◀ עוקף התחברות → ' 0R '1'='1' --

◀ Union-based (פלט ישיר) מול Blind

◀ `-u URL --dbs / --dump` — **sqlmap**

Cross-Site Scripting (XSS)

הזרקת JavaScript לדפדפן קורבן ◀

Reflected · Stored · DOM ◀

`<img src=x onerror=alert(1)>` , `<script>alert(1)</script>` ◀

גניבת Cookie → חטיפת Session ◀

Command Injection

◀ קלט נכנס לפקודת מערכת

◀ `127.0.0.1; whoami`

◀ מפרידים: `` ` && | ;`

◀ **RCE** = מהחמורות ביותר

Broken Access Control / IDOR

◀ A01 — הנפוץ ביותר

◀ **IDOR** : account?id=1001 → ?id=1002

◀ Forced Browsing ל- /admin

◀ שינוי role=admin → role=user

Inclusion-1 File Upload

Upload: Web Shell `<?php system($_GET['cmd']);?>` → RCE ◀

Content-Type , `shell.php.jpg` :עקיפה ◀

`?file=../../etc/passwd` :LFI ◀

RCE → קובץ מרוחק :RFI ◀

כלים

Burp Suite — Proxy, Repeater, Intruder ◀

SQLi אוטומציית **sqlmap** ◀

נתיבים — **ffuf / gobuster** ◀

חולשות נפוצות — **nikto** ◀

הגנה

SQLi מונע → **Prepared Statements** ◀

XSS מונע → **Output Encoding** ◀

בקרת גישה בשרת (לא רק ב-UI) ◀

CSP · HTTPS · CSRF Tokens · MFA ◀

סיכום מודול 9

- ◀ חולשות Web = ארון בקלט
- ◀ Injection (SQLi/XSS/Command), IDOR, Upload
- ◀ הכלים = Burp + sqlmap
- ◀ המיומנות הכי מבוקשת בשוק
- ◀ **תרגול** → `practice.md` · **פתרונות** → `solutions.md`